

Swing Shortcut → Plane Auto-Login Integration — Brainstorm Report

Date: 2026-05-28

Updated: 2026-05-28 17:48 — chốt approach JWT 융복합 (signLogon endpoint mới).

Target: Plane web (workspace.shinhan.com.vn) launched as shortcut từ Swing portal — single-click auto-login.

Spec sources: [Board]20260528_171934_backup/

- (자동로그인)_V0.9.xlsx — JWT auto-login interface
- SL0통신에 따른 스윙자동로그인 가이드.pptx — flow guide + firewall
- (융복합_통합인증 API 연동 가이드)V0.3.docx — đăng ký 융복합 service
- 인터페이스정의서5(조직도, 직원정보)_V0.97.xlsx — employee API cho auto-provision
- (필독사항)방화벽신청정보(서버간)_20260429.xlsx — firewall request form

1. Problem Statement

User đã login Swing portal → click shortcut "Plane" trong menu portal → mở tab mới đến workspace.shinhan.com.vn → **đã login sẵn** (không hỏi password).

Constraint xác định

- Menu Swing portal **chỉ gắn được link static** — không có server-side hook tại thời điểm click.
- Plane & Swing **khác domain** (workspace.shinhan.com.vn vs swing.shinhan.com) → không share cookie.
- **Chỉ được dùng spec/API đã có trong folder backup** — không yêu cầu Swing team build thêm gì mới ngoài việc đăng ký Plane là một 융복합 service.

Mục tiêu

- Single-click auto-login từ Swing portal sang Plane.
- Landing tại workspace.shinhan.com.vn workspace mặc định của user.
- User chưa có Plane account → **auto-provision** từ Swing 조직도 API.

2. Approach chốt — JWT 융복합 (theo spec V0.9 + V0.3)

Pattern: Swing portal làm launcher, Plane là service endpoint

Static URL trong menu portal **trở về Swing IFC**, không trở về Plane. Swing portal đã có sẵn cơ chế "mint token + redirect" cho mọi 융복합 service đăng ký với họ — đây là nội dung core của spec 융복합_통합인증_V0.3 .

- [1] User login Swing portal – có session swing.shinhan.com
- [2] User click shortcut Plane (URL static do Swing assign, ví dụ):
<https://swifc.shinhan.com/ekp/.../launch?service=PLANE>
 (URL chính xác do Swing cấp khi đăng ký service)
- [3] Browser đi tới Swing IFC (cùng domain swifc.shinhan.com → cookie OK)
 Swing portal backend đọc session → biết empNo của user
- [4] Swing portal backend gọi nội bộ POST /ekp/service/openapi/auth/token
 Body: {
 common: { clientId(Base64), clientSecretKey, userType:"empNo" },
 data: { cmpId:"SG", empNo:"12345678" }
 }
 → nhận về { accessToken: <JWT>, expiresInSec }
 JWT claims: { exp, jti, iss:"Groupware authentication", aud, UserIdentity:<encrypted empNo> }
- [5] Swing 302 redirect browser tới:
https://workspace.shinhan.com.vn/auth/signLogon?accessToken=<JWT>&forwardUrl=<URL_PATH>
- [6] Plane signLogon endpoint (CẦN BUILD MỚI):
 - Verify JWT HMAC với SWING_SSO_CLIENT_SECRET_KEY
 - Check exp chưa hết, iss/aud khớp
 - Extract empNo từ UserIdentity claim (decrypt theo spec V0.3)
 - Lookup User theo email "sh{empNo}@swing.shinhan.com"
 - Nếu không có → call 조직도 API → auto-provision User
 - user_login() → set Plane session cookie
 - 302 sang forwardUrl (validate qua get_safe_redirect_url)
- [7] User đã ở trong Plane workspace, login xong, không nhập gì.

Tại sao đây là approach duy nhất khả thi với chỉ tài nguyên có sẵn

- Spec 자동로그인_V0.9 mô tả CHÍNH XÁC pattern này.
- signLogon endpoint là phần sub-system (Plane) implement — spec đã cho ví dụ URL + format param.
- 융복합 portal đã có sẵn machinery mint token + redirect — không yêu cầu Swing team build thêm code, chỉ admin task (đăng ký service).
- Plane endpoint legacy (/auth/swing-sso/callback với XML token) **không match** spec mới → sẽ build endpoint riêng /auth/signLogon .

3. Codebase Findings (Plane hiện trạng)

Thành phần	Path	Tình trạng
Token callback XML (legacy)	apps/api/plane/authentication/views/app/swing_sso_token_callback.py	Đã có nhưng KHÔNG match spec mới — sẽ giữ làm fallback, ưu tiên build endpoint JWT mới

Thành phần	Path	Tình trạng
Password sign-in	apps/api/plane/authentication/views/app/swing_sso.py	Đã có — không liên quan luồng auto-login
Token provider XML	apps/api/plane/authentication/provider/credentials/swing_sso_token.py	Đã có, deprecate sau khi JWT chạy ổn
Admin config UI	apps/admin/app/(all)/(dashboard)/authentication/swing-sso/	Cần extend thêm field <code>clientId</code> , <code>clientSecretKey</code> , <code>signLogonUrl</code>
Config keys	InstanceConfiguration	Cần thêm: <code>SWING_SSO_CLIENT_ID</code> , <code>SWING_SSO_CLIENT_SECRET_KEY</code> , <code>SWING_SSO_JWT_AUDIENCE</code> , <code>SWING_SSO_ORG_API_URL</code>
Email pattern	sh{empNo}@swing.shinhan.com	Giữ nguyên — auto-provision dùng cùng pattern

4. Các bước triển khai (Implementation Steps)

Phase 0 — Admin & approval tasks (không phải code)

- Submit form đăng ký Plane là 융복합 service** với Swing admin team.
 - Service name: PLANE (hoặc theo Swing convention)
 - Callback URL: `https://workspace.shinhan.com.vn/auth/signLogon`
 - Default `forwardUrl`: /
 - Yêu cầu cấp: `clientId` + `clientSecretKey` + URL endpoint `/auth/token` (dev + prod)
- Submit form firewall** (필독사항) 방화벽신청정보(서버간)_20260429.xlsx :
 - Outbound từ Plane API server → `swifcdev.shinhan.com:443` (dev)
 - Outbound từ Plane API server → `swifc.shinhan.com:443` (prod)
- Xin credential 조직도 API** (인터페이스정의서5):
 - Confirm cùng `clientId/clientSecretKey` hay phải xin riêng
 - URL endpoint employee info
- Confirm với Swing team** flow chi tiết:
 - Format chính xác của `forwardUrl` param (`UrlEncoded?`)
 - Thuật toán encrypt `UserIdentity` claim (`AES?` key shared?)
 - JWT algorithm (`HS256?`) + clock skew tolerance
 - Token TTL chính xác

Phase 1 — Backend: signLogon endpoint + JWT provider

- Tạo file mới:** `apps/api/plane/authentication/provider/credentials/swing_sso_jwt.py`
 - Class `SwingSSOJWTProvider(CredentialAdapter)`
 - Method `_verify_jwt(token)` : decode + verify HMAC + check exp/iss/aud + return claims
 - Method `_decrypt_user_identity(encrypted)` : decrypt empNo theo spec V0.3

- Method `set_user_data()` : lookup user → nếu không có gọi `OrgChartService` → tạo user → trả về
2. **Tạo file mới:** `apps/api/plane/authentication/views/app/swing_sso_sign_logon.py`
 - Class `SwingSSOSignLogonEndpoint(View)`
 - GET `/auth/signLogon/?accessToken=<X>&forwardUrl=<Y>`
 - Validate `accessToken` không rỗng
 - Validate `forwardUrl` qua `get_safe_redirect_url` (whitelist workspace.shinhan.com.vn)
 - Gọi provider → `user_login()` → 302 `forwardUrl`
 - Error → 302 sign-in page với error code
 - Reuse rate limit pattern từ `swing_sso.py` (500 req / 5 min per IP)
 3. **Update file:** `apps/api/plane/authentication/urls.py`
 - Add `path("signLogon/", SwingSSOSignLogonEndpoint.as_view(), name="swing-sso-sign-logon")`
 4. **Update file:** `apps/api/plane/authentication/adapters/error.py`
 - Add error codes: `SWING_SSO_JWT_INVALID`, `SWING_SSO_JWT_EXPIRED`, `SWING_SSO_ORG_API_FAILED`, `SWING_SSO_USER_PROVISION_FAILED`

Phase 2 — Backend: 조직도 service + auto-provision

1. **Tạo file mới:** `apps/api/plane/authentication/services/swing_org_chart_service.py`
 - Method `fetch_employee(emp_no)` → dict : gọi `SWING_SSO_ORG_API_URL` lấy `{first_name, last_name, email, dept_code, dept_name}`
 - Timeout 10s, log error, raise `AuthenticationException` khi fail
2. **Update:** `SwingSSOJWTProvider.set_user_data()` logic auto-provision:

```
if not user_exists:
    emp_info = OrgChartService.fetch_employee(emp_no)
    user = User.objects.create(
        email=f"sh{emp_no}@swing.shinhan.com",
        first_name=emp_info["first_name"],
        last_name=emp_info["last_name"],
        is_active=True,
        is_password_autoset=True,
    )
    # Optional: attach vào default workspace
    attach_user_to_default_workspace(user)
```

3. **Câu hỏi business** cần confirm trước:
 - Workspace mặc định cho user mới (slug? role?)
 - Có cần admin approve trước khi join workspace không?

Phase 3 — Config & Admin UI

1. **Update:** `apps/api/plane/license/api/views/configuration.py`
 - Thêm 4 `InstanceConfiguration` keys (đã list ở mục 3)
2. **Update:** `apps/admin/app/(all)/(dashboard)/authentication/swing-sso/`
 - Form fields mới: `ClientID`, `ClientSecretKey` (masked), `JWT Audience`, `OrgAPI URL`
 - Test button: ping `/auth/token` với test `empNo` → confirm Swing connectivity
3. **Migration:** thêm default values cho 4 keys vào fixture `instance_config_variables.py`

Phase 4 — Security hardening

1. **Token replay protection:** cache `jti` đã dùng trong Redis với TTL = JWT expiry → reject duplicate
2. **Rate limit** per `empNo` (không chỉ IP) — chống brute-force scan

3. **Audit log:** mỗi lần login ghi `provider="swing-sso-jwt"` , `emp_no` , `ip` , `user_agent` , `outcome`
4. **forwardUrl safety:** chỉ accept relative path hoặc URL có host == `workspace.shinhan.com.vn`
5. **Clock skew:** tolerate $\pm 30s$ khi verify `exp`

Phase 5 — Testing

1. Unit tests:

- JWT verify happy path
- JWT expired → reject
- JWT signature invalid → reject
- UserIdentity decrypt mismatch → reject
- jti replay → reject
- forwardUrl open-redirect attempt → reject
- Auto-provision happy path
- 조직도 API timeout → reject với proper error

2. Integration test với Swing dev env (`swifcdev.shinhan.com`):

- End-to-end: gọi `/auth/token` thật → nhận JWT → POST sang Plane `signLogon` → verify Plane session cookie được set

3. Manual UAT:

- Click shortcut trên Swing dev portal → kiểm tra tab Plane mở + logged in
- User chưa có Plane account → kiểm tra auto-provision
- Token hết hạn → kiểm tra redirect về sign-in page với message hiểu được

5. Files sẽ tạo / sửa

Tạo mới

- `apps/api/plane/authentication/provider/credentials/swing_sso_jwt.py`
- `apps/api/plane/authentication/views/app/swing_sso_sign_logon.py`
- `apps/api/plane/authentication/services/swing_org_chart_service.py`
- `apps/api/plane/tests/unit/authentication/test_swing_sso_jwt.py`

Sửa

- `apps/api/plane/authentication/urls.py` — thêm route
- `apps/api/plane/authentication/views/__init__.py` — export
- `apps/api/plane/authentication/adapters/error.py` — thêm error codes
- `apps/api/plane/license/api/views/configuration.py` — thêm config keys
- `apps/api/plane/utils/instance_config_variables/core.py` — thêm defaults
- `apps/admin/app/(all)/(dashboard)/authentication/swing-sso/page.tsx` — UI mới
- `apps/admin/app/(all)/(dashboard)/authentication/swing-sso/components/*.tsx` — form fields mới

Có thể deprecate sau Phase 5

- `apps/api/plane/authentication/views/app/swing_sso_token_callback.py` (XML legacy)
- `apps/api/plane/authentication/provider/credentials/swing_sso_token.py`

6. Security Considerations

Risk	Mitigation
JWT secret leak	Lưu InstanceConfiguration encrypted, env override, rotate định kỳ, không commit
Token replay	jti cache trong Redis với TTL = JWT exp
Token trên URL bị log	TTL ngắn (<60s), one-time use enforce, khuyến nghị Swing dùng POST nếu support
Open redirect qua forwardUrl	get_safe_redirect_url whitelist host, reject absolute external URL
Auto-provision spam	Rate limit per IP + per empNo, verify empNo format (8 digit)
Race condition tạo user trùng	get_or_create với DB unique constraint trên email
조직도 API outage	Cache employee info 1h, fallback empNo làm display name nếu API fail
Clock skew	Tolerate ±30s, sync NTP
Session fixation	Rotate session id sau login (Django default)

7. Success Criteria

- ☐ User có Plane account → click shortcut → mở tab Plane đã login ≤ 3s
- ☐ User chưa có Plane account → auto-provision thành công lần đầu click
- ☐ Token invalid/expired → redirect về sign-in page với error message rõ
- ☐ Replay JWT cũ → reject
- ☐ Session cookie Plane set với Secure; HttpOnly; SameSite=Lax
- ☐ Audit log đầy đủ mỗi lần login
- ☐ Unit test coverage > 85% cho JWT provider + signLogon view
- ☐ E2E test pass trên swifcdev environment

8. Effort Estimate

Phase	Effort	Owner
Phase 0 (admin/firewall/registration)	1-2 tuần (lead time của Swing team)	Bạn submit, chờ approve
Phase 1 (JWT endpoint + provider)	2-3 ngày	Plane backend
Phase 2 (org chart + auto-provision)	1-2 ngày	Plane backend
Phase 3 (config + admin UI)	1-2 ngày	Plane fullstack
Phase 4 (security hardening)	1 ngày	Plane backend
Phase 5 (test + UAT)	2-3 ngày	Plane + Swing dev team
Total	~2 tuần dev + Phase 0 chờ	

→ Phase 0 chạy song song với code dev Phase 1-3.

9. Next Actions

1. **Bạn:** submit form đăng ký 융복합 service + firewall + xin credential 조직도 (Phase 0).
2. **Bạn:** trong lúc chờ, đọc kỹ doc 융복합_통합인증_V0.3.docx để confirm:
 - Thuật toán decrypt `UserIdentity` claim
 - JWT algorithm + audience format
 - 조직도 API endpoint + auth scheme
3. **Sau khi có credential dev:** chạy `/ck:plan` để break Phase 1-5 thành tasks chi tiết với file paths cụ thể.
4. **Implement** trên branch `ngoc-feat/swing-sso-jwt` (tách khỏi `categories` branch hiện tại).

10. Unresolved Questions (cần Swing team confirm trước Phase 1)

1. URL chính xác của `/auth/token` cho dev (`swifcdev`) và prod (`swifc`).
2. URL chính xác mà Swing portal sẽ redirect tới (Plane signLogon path).
3. Format `clientId` (Base64 của gì? "26자리" theo doc?).
4. JWT algorithm: HS256 hay khác? Audience claim cấu trúc?
5. Thuật toán decrypt `UserIdentity` — spec V0.3 chi tiết chỗ nào?
6. Token TTL chính xác — bao nhiêu giây?
7. Token có phải one-time không (hỗ trợ replay protection bằng cách nào)?
8. 조직도 API: cùng credential 융복합 hay khác? URL endpoint? Response schema?
9. Có cần Plane public IP whitelist phía Swing không (ngoài firewall outbound)?
10. Workspace mặc định attach user mới — slug nào? Role mặc định? Có cần admin approve?